

AppE.2 Mobile Financial Services Technologies

Financial institutions implement and offer MFS through technologies such as the following:

- Short message service (SMS)/text messaging.
- Mobile-enabled Web sites and browsers.
- Mobile applications.
- Wireless payment technologies.

AppE.2.a Short Message Service

SMS is a text messaging service component of phone, Web, or mobile communication systems. SMS uses standardized communications protocols to allow devices to exchange short text messages. Messages are typically limited to 160 characters and communicate either between mobile devices or between businesses and mobile devices (e.g., financial institutions requesting customer verification of transactions). Within the context of MFS, a customer uses SMS to provide financial transaction instructions to their financial institution. Financial institutions use SMS to provide information to customers, including account alerts or to communicate one-time passwords for Web site authentication.

AppE.2.b Mobile-Enabled Web Sites

A mobile device's browser allows customers to access a financial institution's Web site. Many financial institutions provide mobile-enabled Web sites, in addition to their regular Web site, which may improve the customer experience. The mobile-enabled Web site is designed to detect the type of device the customer is using (e.g., mobile device or desktop computer) and displays Web pages in the best format for that device.

AppE.2.c Mobile Applications

Mobile applications are downloadable software applications developed specifically for use on mobile devices. Mobile financial applications are developed by or for financial institutions to allow customers to perform account inquiries, retrieve information, or initiate financial transactions. This technology leverages features and functions unique to each type of mobile device and often provides a more user-friendly interface than is possible or available with either SMS or Web-based mobile banking.

AppE.2.d Wireless Payment Technologies

Customers may use mobile technologies to initiate wireless payments at point-of-sale (POS) terminals, make person-to-person (P2P) payments, or make other types of wireless payments, such as parking meter and mass transit access payments. Mobile wallets³ allow customers to make wireless payments with a virtual payment card, as opposed to a physical card. The

³ A mobile wallet is a front-end application that stores payment card information on the mobile device and allows payments to be made using a mobile device. The mobile wallet utilizes traditional retail payment channels such as ACH, EFT, and debit/credit card networks to process the payments.

exchange of payment credentials and authorization between the mobile device and the payment recipient can use different core technologies. Technologies that provide the ability to make wireless payments include the following:

- **Near field communication (NFC).** Wireless protocol that allows for exchange of payment credentials stored on the mobile device and other data at close range. For example, NFC is used to facilitate mobile payment systems developed by mobile phone manufacturers in conjunction with issuing financial institutions.
- **Image-based.** Coded images similar to bar codes used to initiate payments. Credentials may be encoded within an image or stored in the cloud. For example, specific retailers use quick response (QR) codes⁴ to identify customers in a closed-loop mobile payment⁵ system.
- **Carrier-based.** Payments billed directly to a customer's mobile carrier account. Merchants are paid directly by the mobile carrier, bypassing traditional payment networks. For example, a carrier-based payment may occur when mobile users donate money to charity through SMS messages.
- **Mobile P2P.** Payments initiated on a mobile device using the recipient's mobile phone number, e-mail address, or other identifier. Payment is through established retail payment technologies. For example, customers may download a P2P mobile application from their financial institution that allows them to send money to other users enrolled in the institution's system.

Although these technologies help facilitate financial institution-centric mobile payments, established retail payments channels (automated clearing house (ACH), credit/debit networks, electronic funds transfer (EFT), and intra-account transfers) remain the principal methods by which mobile payments are funded⁶ and settled in the U.S. marketplace. With traditional retail payments channels serving as the backbone of mobile payments, users typically are required to provide verifiable financial institution account information or a credit, debit, or prepaid card to establish and fund a mobile payments service. The traditional retail payments channels allow financial institution mobile payments providers to leverage existing banking relationships to verify identities, satisfy federal anti-money laundering requirements, and fund accounts.

AppE.3 Risk Identification

Management should identify the risks associated with the types of MFS being offered as part of the institution's strategic plan. Management should incorporate the identification of risks associated with mobile devices, products, services, and technologies into the financial institution's existing risk management process. The complexity and depth of the MFS risk identification varies depending on the functionality provided through the mobile channel and the

⁴ A QR code is a type of two-dimensional bar code or machine-readable optical label that contains information about the item to which it is attached.

⁵ Closed-loop payments allow consumers to pre-load funds into a spending account that is linked to the payment device that can be used for purchases only at a specific company. Open-loop payments allow consumers to tie a mobile wallet to a personal account (e.g., credit card), do not require a prepaid amount, and spending is not limited to one company.

⁶ Funding refers to adding a positive balance that customers use to make purchases.

type of data in transit and at rest.

The identification process should include risks at the institution and those associated with the use of mobile devices where the customer implements and manages the security settings. In providing customers with avenues for performing banking activities through mobile devices, an institution may transfer to the customer the ability to implement security settings. This transfer increases dependence on the customer to manage the controls over sensitive financial data. Additionally, there are numerous types of mobile devices that present different risks, and management should identify unique risks associated with specific devices. Before implementing mobile products and services, management should identify the associated risks, particularly in the areas of strategic, operational, compliance, and reputation risks.

AppE.3.a Strategic Risk

When financial institution management fails to incorporate its decisions regarding MFS into its strategic planning, the institution's level of strategic risk may increase. Management should identify the risks associated with the decision to offer MFS and determine what types of MFS best fit with the strategic vision, goals, and risk appetite of the institution.

AppE.3.b Operational Risk

MFS introduce unique operational risks. Management should identify the risks involved with transaction initiation, authentication and authorization, and the MFS technology itself. Some of the operational risks are associated with the mobile device and how the device communicates with the POS or other similar terminal.⁷ Additionally, the varying access points⁸ provide challenges with authentication and security.

MFS provide the opportunity to leverage tools and techniques not available in traditional banking payment products. The prevalence of mobile devices, common operating systems, and downloadable applications make these devices a target for malware and viruses. Without implementing additional controls, basic device access controls such as personal identification numbers (PIN) may not be adequate to protect data that is stored on a mobile device because these controls could be circumvented by someone who has unrestricted physical access to the device. Additionally, a fraudster can compromise mobile application-based financial services by developing rogue, corrupted, or malicious applications (or adding rogue code to applications) that a customer downloads to his or her mobile device. Therefore, management should consider the implications of operational risks when evaluating and implementing such technologies.

⁷ Traditional payment risks associated with the underlying payment transaction are covered by existing risk management guidance contained in earlier sections of this booklet.

⁸ Access points include a user's home network, cellular network, NFC, Bluetooth, or public Wi-Fi connections, such as those provided by a municipality or business.

AppE.3.b(i) SMS Technology Risk

SMS technology presents a number of security-related risks. SMS messages typically are transmitted unencrypted over widely used telecommunications networks. The messages are also vulnerable to spoofing,⁹ which allows an unauthorized user to send an SMS message pretending to be from a different mobile number to mislead a customer into providing sensitive information to the unauthorized user. Similarly, fraudulent SMS messages may mislead customers into revealing financial institution account information or information used to access financial institution systems.

AppE.3.b(ii) Mobile-Enabled Web Site Risk

Mobile-enabled Web sites rely on existing Internet security protocols, which make the sites subject to many of the same vulnerabilities¹⁰ that can compromise computer-based banking. Additionally, mobile devices can be limited by their hardware and operating systems, which can result in a reduced level of security. Mobile Web browsers are common starting points for malicious attacks, and malicious messages can come from many other sources.¹¹ Whereas desktop browsers have anti-phishing¹² and anti-cross-site scripting (anti-XSS) capabilities¹³ to filter out the malicious code from Web sites, mobile-enabled browsers do not always have such features. The lack of anti-phishing and anti-XSS modules can increase the possibility of loss of sensitive information when using a mobile device.

As is the case with any Web-based application, attacks involving unvalidated “redirects and forwards”¹⁴ can be used to maliciously craft a URL¹⁵ to bypass the application’s access control check and then provide the attacker access to privileged functions that normally would not be accessible to them. The attacks also can lead to malware download and installation. By modifying a URL and redirecting the browser to a malicious site, an attacker may successfully launch a phishing scam and steal user credentials.

Users often find it difficult to recognize a phishing message or a forged Web site, or determine

⁹ SMS spoofing is the manipulation of address information to impersonate a user.

¹⁰ Vulnerabilities include malware attacks, eavesdropping, and spoofing.

¹¹ Besides e-mail and instant messages, sources can also include SMS, social messengers, hypertext markup language (HTML) links, and QR codes.

¹² Anti-phishing software are programs, either integrated with or built in to the Web browser, that display the real domain name of the site that a user is visiting to help prevent fraudulent sites from posing as legitimate sites.

¹³ Anti-XSS functionality is a defense mechanism to XSS, which is a vulnerability found in Web applications that enables attackers to inject client-side script into Web pages prompting a Web page to display unvalidated user input. Attackers may use this vulnerability to bypass access controls.

¹⁴ Unvalidated Web site redirects are possible when a Web application accepts untrusted input that could cause the application to redirect the request to a malicious URL. A user may be redirected and not realize it.

¹⁵ URL is an acronym for uniform resource locator and is a reference (an address) to a resource on the Internet.

whether a site is safe. Additionally, mobile browsers displayed on small screens may not effectively display the same visual security cues more easily seen on full-scale browsers on large screens.

AppE.3.b(iii) Mobile Application Risk

Applications can be downloaded onto mobile devices from a number of application stores. Although device manufacturer-authorized application stores perform due diligence, applications may still contain vulnerabilities that cause risks to the user and the financial institution. On some mobile devices, it is possible to download an application from application stores not authorized by the manufacturer, which poses a greater risk of users being exposed to malicious code because the applications may not be adequately reviewed by the store. Distribution of malware through applications is a material risk to the institution and its customers because of malware's ability to compromise sensitive data and monitor communications.

Another risk to the institution and its customers occurs with the end user's ability to access root user¹⁶ privileges in the operating system of the device. The process to gain access is known as "rooting." Another method of removing the manufacturer's device controls or core operating system controls is "jailbreaking." Jailbreaking provides the user with additional access to and control over the device's operating and file systems, including the ability to circumvent security controls. For certain mobile devices, rooting and jailbreaking allow the user to download applications from untrusted sources, which may introduce malware onto the device.

Many applications store usernames, passwords, and e-mail addresses in clear text. Because users often have the same usernames and passwords across systems, it is possible to use the information obtained from a poorly designed mobile application to compromise user accounts on other systems. Mobile applications collect personal information (e.g., name, account number, and other personal details) and track user activity (e.g., purchases and location). These data are valuable to attackers and can result in compromised user privacy. Without properly securing the mobile application, unauthorized users can gain access to the back-end databases containing confidential information.

The mobile ecosystem is the collection of carriers, networks, platforms, operating systems, developers, and application stores that enable mobile devices to function and interact with other devices. Vulnerabilities may exist in any area of this decentralized mobile ecosystem and, therefore, result in a multi-entity patch management process among mobile device operating system developers, device manufacturers, wireless carriers, and other application developers. As a result of the decentralized ecosystem of some devices, a known vulnerability may remain unremediated while the various parties review, update, and ensure compatibility with their applications and the security mitigation. Additionally, integrating MFS application functionality with other applications and services on the customer's device may introduce vulnerabilities because MFS applications are not built in or native to the device.

AppE.3.b(iv) Mobile Payments Risk

¹⁶ The root user is the conventional name of the user who has all rights or permissions to all files and programs. Having such rights or permissions allow the root user to do many things an ordinary user cannot.

The portability of mobile devices can lead to the devices being misplaced or stolen, which may allow unauthorized access to the mobile wallet or user credentials. Such access can result in unauthorized payments and funds transfers and fraudulent purchases.

Because mobile payments at the POS may use NFC, communications between the device and the POS terminal can be intercepted, while the device is in the user's possession. Even if these communications are encrypted, which they are not by default, there remains a potential for unauthorized access to transaction information, which could be used to perpetrate financial fraud.

Vulnerabilities create the potential to take advantage of weak security controls in the payment provisioning or enrollment functions of the NFC payment system process to commit fraud. Malicious actors using stolen identity information (e.g., from credit reports, tax records, health care records, and employee records) may establish fake accounts on NFC-enabled mobile devices to make unauthorized transactions.¹⁷

AppE.3.c Compliance Risk

Financial institution management should identify the compliance risks as it determines which MFS to offer and continue to monitor these risks as the technology for MFS evolves. Consumer laws, regulations, and supervisory guidance that apply to a given financial product or payment method generally apply regardless of the technology used to provide the products and services.

One of the challenges in providing MFS is that a significant portion of the innovation in the industry is driven by entities outside of the traditional financial services sector. These entities may be unfamiliar with regulatory requirements and supervisory expectations that apply to regulated financial institutions and their service providers. Management should understand how the institution's risk profile changes when it uses any third party, but particularly a third-party service provider that is unfamiliar with the regulation and supervision of the financial services sector, to design applications.

AppE.3.d Reputation Risk

Management should identify and consider how providing MFS may create reputation risk. Reputation risk is particularly relevant in the context of privacy and data security, as public scrutiny of the treatment of customer information continues to grow. The mobile channel, with many of its activities trending toward personalization¹⁸ and transmission of data, poses a risk of disclosure of personal information. Additionally, services provided by a third party that are not implemented appropriately or securely may expose the financial institution to reputation risk if interruptions in service occur or sensitive customer information is compromised.

AppE.4 Risk Measurement

¹⁷ Refer to U.S. Secret Service and PCI Security Standards Council, "Joint Advisory Bulletin: Mobile Payment System Vulnerability," September 2015.

¹⁸ Personalization is providing a tailored user experience based on user preferences through MFS.

The identification of risks should be followed by a measurement of the level and types of risks involved in offering MFS. Management should measure potential risks across all applicable risk categories. This assessment may help management determine the likelihood and impact of the risks affecting the institution. The results should be prioritized to determine which controls may be appropriate for the services provided by the institution. This process should be ongoing and updated whenever management implements a change to the strategy or MFS.

AppE.5 Risk Mitigation

Effective enterprise-wide risk management helps management determine whether controls are effective and goals are compatible with the financial institution's risk appetite and strategic plan. When offering MFS, management should mitigate identified risks by implementing effective controls across the institution. As is the case with any new product offering, management should develop and implement policies and procedures to comply with applicable laws and regulations and require appropriate internal controls for security and confidentiality of the MFS transactions. As part of the institution's audit of retail payments systems, audit coverage should include MFS.

Unlike many financial services that allow institutions to control much of the interaction, MFS typically require the coordinated and secure exchange of information among several unrelated entities. Depending on the type of MFS offered, institutions may find that the effective management of risks involves interaction with application developers, mobile network operators, device manufacturers, specialized security firms, and other nonfinancial third-party service providers. Additionally, financial institution management should provide security awareness materials to the institution's customers, which may include prudent security practices for the device (e.g., use of mobile anti-malware, PIN protection) so that customers understand their roles in securing the device and the need for such security.

AppE.5.a Strategic Risk Mitigation

Financial institution management should incorporate decisions on providing MFS into its strategic planning process. Various elements should be part of any mobile strategy, including the products and services to be offered, types of transactions allowed, limits over transaction amounts, mobile architecture design, supported mobile devices, customer needs, and use of third parties.

AppE.5.b Operational Risk Mitigation

Financial institution management should develop a layered approach to mitigate operational risks from MFS. This may include implementing security techniques at the server and database level; using transaction monitoring and geolocation techniques to identify anomalous MFS transactions; implementing and refining fraud prevention, detection, and response programs that facilitate rapid notification of potentially fraudulent transactions; applying additional controls (e.g., stronger authentication, encryption) to prevent unauthorized access to sensitive customer information stored on the device; and educating customers and employees to identify social engineering attempts that could lead to fraud.

The following are general operational controls that an institution should consider when implementing MFS.

- **Enrollment.** Financial institution management should have appropriate controls and communication of policy and procedures to verify a customer's identity when enrolling customers in mobile payment systems used at the point of sale (e.g., allowing a customer with a physical payment card the ability to enroll that card into the customer's mobile wallet).
- **Authentication and authorization.** A financial institution should have a process for authenticating users of MFS to protect customers against fraudulent transactions or malicious activities. Depending on the technology used and associated level of risk, financial institutions may consider biometric (e.g., voice, fingerprint, facial recognition) or out-of-band¹⁹ authentication processes. The financial institution should not use mobile payment applications that rely on less secure (e.g., single factor) methods of authentication.²⁰
- **Application development and distribution.** The application development life cycle should include a thorough design and architecture review using threat-modeling²¹ techniques to reduce potential risks and meet the financial institution's security objectives. Additionally, application developers should develop applications using secure coding techniques,²² and applications should be rigorously tested for vulnerabilities (e.g., detailed code analysis and white-hat hacking²³) at least annually. Institutions should distribute applications and updates securely and in a timely fashion. Management should consider designing anti-malware capabilities into mobile applications. Applications should not retain sensitive customer information on the device, such as user IDs and passwords, and the application should securely wipe any sensitive customer information from memory when the customer exits the application. If a third party developed the application, the third-party developer should incorporate these control requirements into its development process.
- **Application security.** Management should ensure that the institution's MFS contain log-on credentials in addition to those used to access the device. Management should employ multi-

¹⁹ Out-of-band refers to activity outside of the primary means of interfacing with the customer. For example, if a user is performing activity online, he or she may be authenticated through a one-time password sent via text message.

²⁰ Resources that provide detailed information about authentication for financial institutions include: FFIEC Authentication Guidance (http://www.ffiec.gov/pdf/authentication_guidance.pdf), Frequently Asked Questions (https://www.ffiec.gov/pdf/authentication_faq.pdf), and Authentication Supplement ([https://www.ffiec.gov/pdf/Auth-ITS-Final%206-22-11%20\(FFIEC%20Formatted\).pdf](https://www.ffiec.gov/pdf/Auth-ITS-Final%206-22-11%20(FFIEC%20Formatted).pdf)).

²¹ Threat modeling is a structured approach that enables an institution to aggregate and quantify potential threats. In the context of application development, threat modeling can be used to capture, organize, and analyze all of the threat information of an application and its environment that affects application security. It is used to enable informed decision-making about application security and helps to produce and rank a list of security improvements.

²² Secure coding is the process of developing code (e.g., Web application) with security built in during the development process using technical controls to mitigate the occurrence of software vulnerabilities.

²³ White-hat hacking, also called ethical hacking, refers to the specialization of penetration testing and other testing methodologies to review the security of an institution's information systems by determining flaws and vulnerabilities.

factor authentication or layered security controls depending on the types and volumes of transactions. The system should require re-authentication whenever the device or MFS is unused for a designated period and each time the user launches the application.

- **Contracts.** The institution should use well-constructed contracts, developed with legal counsel, to mitigate its risks from third parties. Contracts should be appropriate for the institution's specific mobile strategy and should clearly identify each party's roles and responsibilities. Financial institution management may need to establish contracts with the institution's customers and third parties that cover types of data collected and circumstances related to data sharing.
- **Customer awareness.** Financial institution management should make reasonable efforts to educate customers about the need to maintain the physical and logical security²⁴ of mobile devices and suggest that users regularly install operating system and firmware updates. Management should make clear that customers should download applications only from reputable sources, and the institution's Web site should have a link to the source of any institution-approved applications. Institutions should have customer security awareness materials available to help customers understand the risks involved in using MFS, including the use of unsecured "public" wireless networks. Financial institutions should suggest that customers consider running anti-malware software on their mobile devices, if possible.
- **Logging and monitoring.** Management should have logging and monitoring capabilities on all MFS to track customer activity and security changes and identify anomalous behavior and transactions.

AppE.5.b(i) SMS Technology Risk Mitigation

Financial institution management should employ compensating controls (e.g., redacting customer account numbers when sent via SMS) to mitigate the inability to encrypt SMS messages. Additionally, management should limit the access or functionality available to the customer through SMS banking. When the transaction risk is more significant, management should consider other risk mitigation methods, including pre-registration and the use of security tokens. PINs also could be employed, but are often easier to break and harder to remember. To strengthen the security of PIN usage, management can implement specific requirements (e.g., requiring them to be regularly changed). An institution should update its customer awareness materials to include information on avoiding phishing messages by SMS.

AppE.5.b(ii) Mobile-Enabled Web Site Risk Mitigation

Financial institution management should consider several controls to mitigate risks associated with mobile-enabled Web sites, including the following:

- Provide specific training and security awareness materials for users and customers accessing the institution's sites to teach them how to identify compromised sites.
- Require Web site developers to follow a secure development life cycle to increase the security of the Web sites designed for the financial institution.

²⁴ Prudent security practices may include information on the use of the device's password function, general safeguards, and any additional logical security controls (e.g., available security applications).

- Require developers to build a secure Web site especially for mobile devices and encourage them to follow the guidelines provided from the Open Web Application Security Project (OWASP)²⁵ Top 10 for Web application and OWASP Top 10 for mobile.
- Make available a baseline set of controls, and educate customers on the use of those controls to protect their device and information (e.g., device passwords with complexity, application passwords, and an auto-wipe feature after excessive password failures).
- Determine whether mobile browsers have available safeguards implemented, such as anti-XSS modules or additional monitoring of browsers for those that are no longer supported, and deny access to devices with mobile browsers not meeting minimum standards.
- Determine whether mobile-enabled Web sites are designed with the following mitigating controls to help minimize the potential for exploitation of “redirect and forward” vulnerabilities:
 - Avoid using redirects and forwards.
 - Explicitly hard code the URL to prevent manipulation by an attacker.
 - Apply additional validation or control checks to verify the user trying to access the URL, validate the URL, check the appropriateness of the URL request, and prevent a malicious user from redirecting site users to a phishing, malicious, or nonaffiliated site.
 - Create a whitelist²⁶ of trusted URLs.
 - Force all redirects to go through a page that notifies a user that he or she is leaving the page and require user confirmation.
 - Perform frequent vulnerability scans.

AppE.5.b(iii) Mobile Application Risk Mitigation

Management should consider the use of a variety of security mechanisms for mobile applications and should evaluate, prioritize, and implement appropriate mitigating controls, including the following:

- Employing tools, such as policy enforcement and device fingerprinting, to determine whether a customer’s mobile device will be allowed to access the institution’s MFS by validating device characteristics (e.g., level of security controls, operating system type, operating system version, whether the mobile device is rooted or jailbroken, and patch status).
- Providing security awareness training to end users to help them recognize legitimate applications and provide a list of reputable sites to download institution-approved applications.
- Performing security testing at all post-design phases of the system development life cycle for all applications. Establishing a process to deactivate older application versions that no longer meet minimum security requirements or prompt the end user to upgrade to an acceptable version.
- Providing basic customer education relative to security to mitigate the risks associated with rooted or jailbroken devices.

²⁵ OWASP is an online community dedicated to Web application security.

²⁶ A whitelist is a list of trusted entities. With respect to URL redirects, an institution can create a whitelist of allowable URLs.